Cumplimiento ENS / NIS2

Este inventario ha sido diseñado conforme a los requisitos del Esquema Nacional de Seguridad (RD 311/2022) y la Directiva NIS2.

Esquema Nacional de Seguridad · RD 311/2022

Inventario de activos completo: Hardware IT, Software y Activos OT/ICS registrados y clasificados.

Categorías del sistema: La dimensión con valor más alto determina la categoría global (Básica, Media o Alta).

Exportación auditable: Generación de fichero .xlsx con todas las dimensiones ENS para auditores y responsables de seguridad.

DIMENSIONES DE VALORACIÓN (ANEXO I)

ENS-D · Disponibilidad
¿Qué ocurre si este activo deja de estar accesible? Evalúa el impacto de una parada temporal o permanente del servicio.

ENS-I · Integridad
¿Qué ocurre si alguien modifica o altera este activo/dato sin permiso? Evalúa el daño por manipulación no autorizada.

ENS-C · Confidencialidad
¿Qué ocurre si accede a este activo quien no debe? Crítico para datos personales, secretos comerciales o contraseñas.

ENS-A · Autenticidad
¿Podemos garantizar quién es el autor o emisor? Evalúa el riesgo de suplantación de identidad en el sistema.

ENS-T · Trazabilidad
¿Podemos rastrear quién ha accedido o modificado el activo? Fundamental para auditorías y análisis forense (Logs).

Directiva NIS2 (UE) 2022/2555 — Resiliencia y Cadena de Suministro

Activos críticos identificados: Clasificación de criticidad diferenciada entre impacto en producción y riesgo físico.

Mapa de dependencias: Registro de dependencias entre activos para identificar propagación de incidentes en caso de caída.

MÉTRICAS CLAVE NIS2

RTO (Recovery Time Objective)
Tiempo máximo que la organización puede tolerar que este activo esté fuera de servicio antes de sufrir consecuencias graves.

Criticidad del Proveedor
Seguridad de la cadena de suministro. Evalúa qué ocurre si el proveedor de este software o hardware es hackeado o quiebra.

Seguridad OT / ICS (Tecnología de Operaciones)

La directiva NIS2 pone especial foco en los entornos industriales debido a su impacto en infraestructuras críticas.

Modelo de Referencia Purdue
Clasifica los activos desde el Nivel 0 (Proceso físico/Sensores) hasta el Nivel 3 (SCADA). Los niveles 0-2 son críticos y deben estar aislados.

Conexión a Red IT (Air-gap)
Es el campo más crítico. Históricamente, los grandes ciberataques industriales (Stuxnet, NotPetya) entraron por conexiones IT-OT no controladas.

Riesgo Safety (Vida Humana)
A diferencia de IT, un ciberataque en OT puede causar daños físicos o la muerte si altera válvulas, presiones o robótica industrial.

Alcance del inventario cubierto

Hardware IT: Equipos de usuario, servidores, infraestructura de red, periféricos y dispositivos IoT.

Software y licencias: Aplicaciones, sistemas operativos, licencias con fecha de caducidad y tipo de contrato.

OT / ICS Industrial: PLC, HMI, SCADA/DCS, estaciones de ingeniería, sensores, actuadores y firewalls industriales.

Aviso legal
Este inventario es una herramienta de apoyo a la gestión. La certificación ENS y la auditoría NIS2 requieren evaluación por organismo acreditado. Consulte con su CISO o responsable de seguridad.